

GET /api/students  
Host : localhost:8080

Controller

Security ??

Assets  
Threat  
Trust Boundary

Assets

Data Assets  
Operational Assets  
Security Assets  
Infra Assets  
Availability Assets

Threat

Vulnerability

Attack

Attacker

/admin

Attack

Application

unlimited passwords attempt

Trust Boundary

Browser



Browser --> Internet --> application



/api/admin



MFA (Multi Factor Authentication)

Authorization ROLE



username  
password

password2

password3

Identity  
Credentials  
Principal  
Authorities  
Roles  
Permissions  
Authentication  
SecurityContext  
SecurityContextHolder

101 Aditya 29

Identity User, Customer, Scheduled Job

Credentials

Principal

Interface  
Authentication

Authorities

COURSE\_READ, USER\_DELETE

Role

ADMIN, USER, MANAGER

Authentication

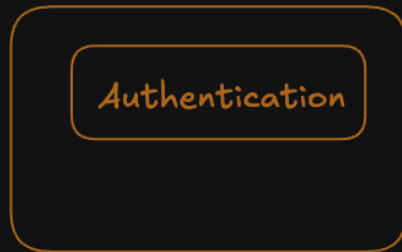
Authentication Request

principal = "Aditya"  
credentials = "raw-password"  
authorities = []  
authenticated = false

Authentication Principal

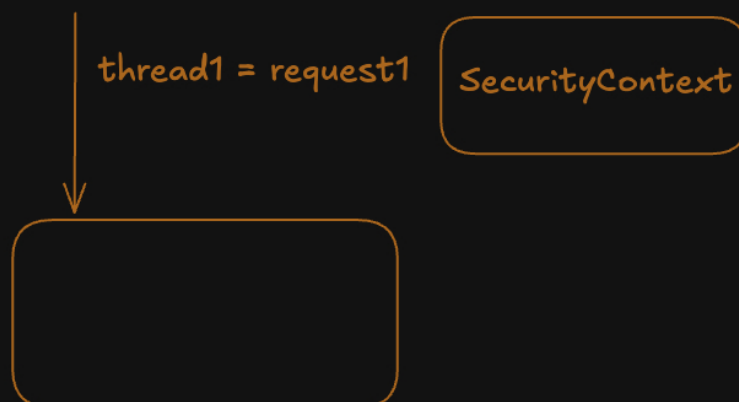
principal = UserDetails("Aditya")  
credentials = null  
authorities = [COURSE\_READ, COURSE\_UPDATE]  
authenticated = true

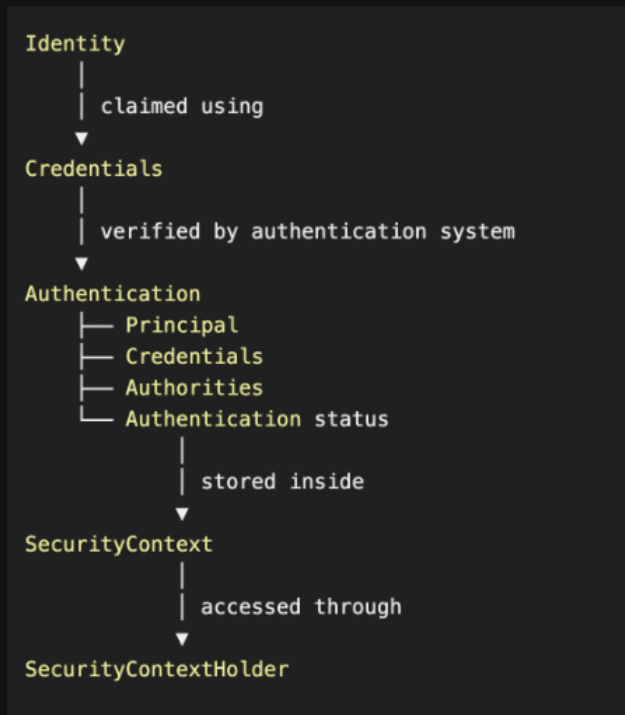
```
public interface Authentication {  
  
    Object getPrincipal();  
  
    Object getCredentials();  
  
    Collection<? extends GrantedAuthority> getAuthorities();  
  
    Object getDetails();  
  
    boolean isAuthenticated();  
  
    String getName();  
}
```



container

```
SecurityContext context =  
    SecurityContextHolder.getContext();  
  
Authentication authentication =  
    context.getAuthentication();  
  
Object principal = authentication.getPrincipal();
```



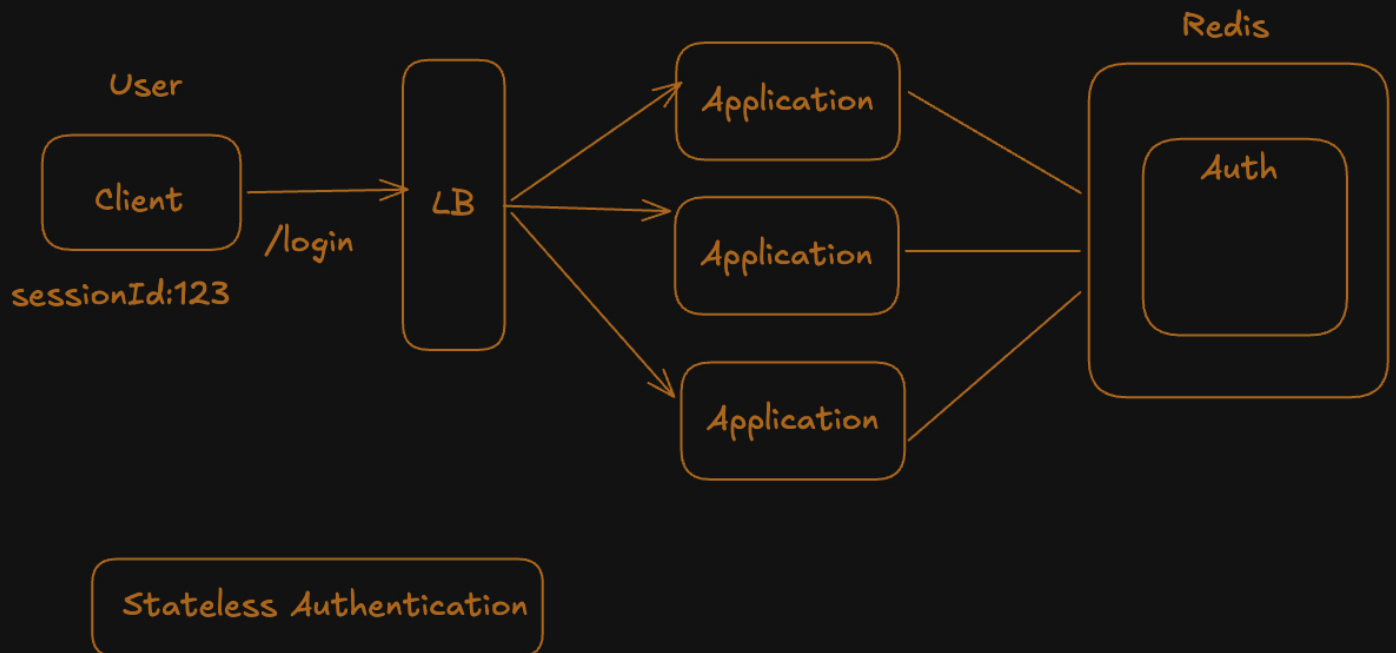
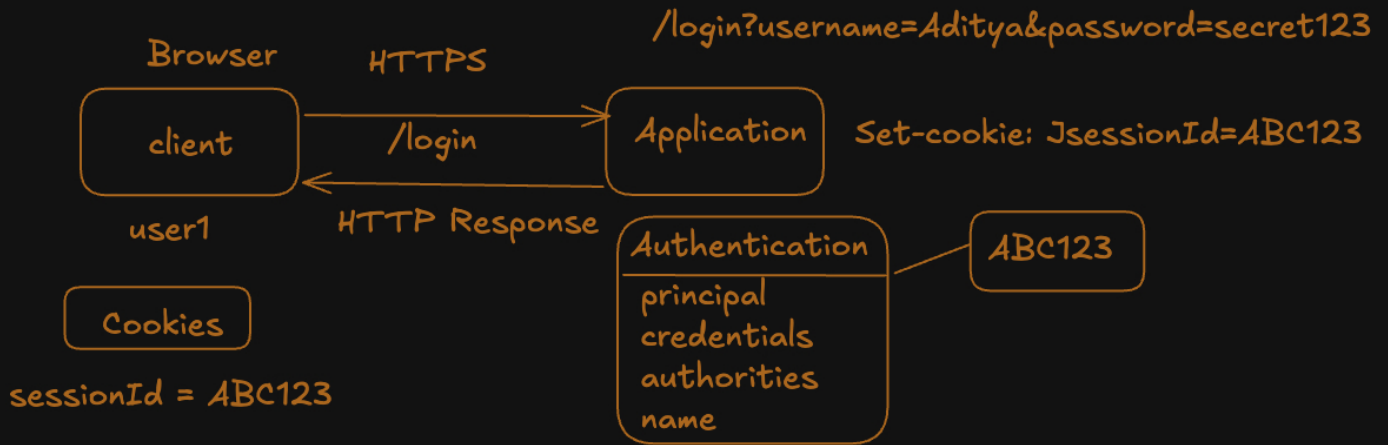


## Authentication States

Stateful Authentication  
Stateless Authentication



## Stateful Authentication



Request1  
Token : <randokm-token>

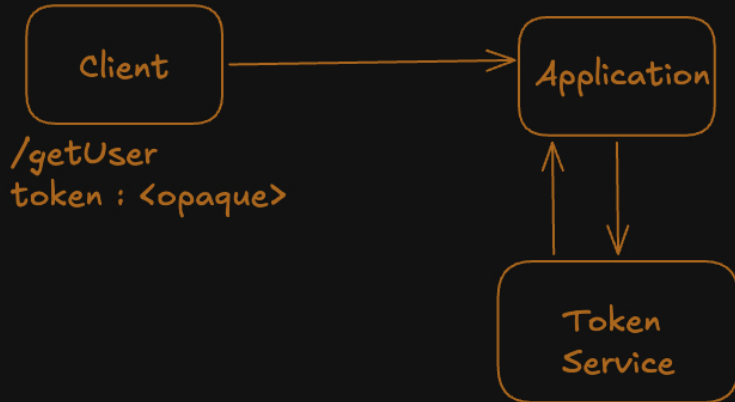
Authentication

Request2  
Token : <random-token>

Self contained vs Opaque Token

JWT

ae3q432e23322131



Bearer Trh2343adsa

HTTP Basic



## Stateful Request Lifecycle

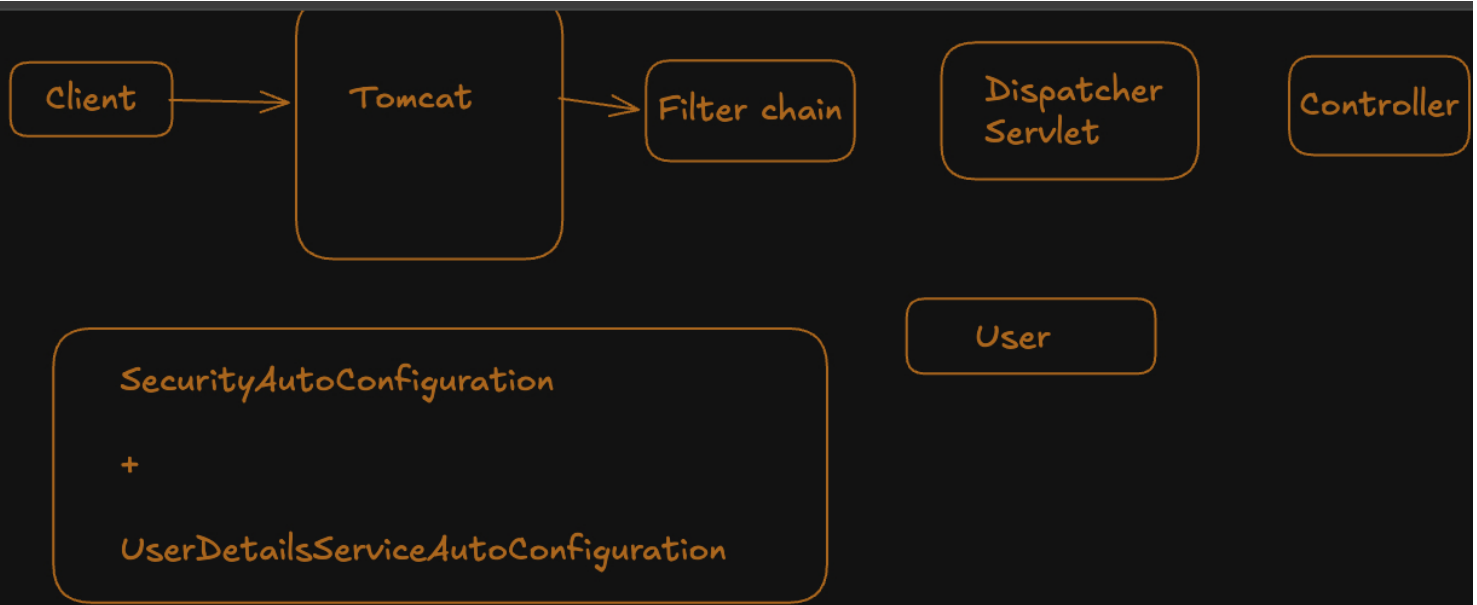
```
POST /login
↓
Username and password extracted
↓
Credentials authenticated
↓
Authentication created
↓
SecurityContext created
↓
SecurityContext saved in HttpSession
↓
Session cookie returned
```

```
GET /profile
Cookie: JSESSIONID=ABC123
↓
Session loaded
↓
SecurityContext loaded
↓
Authentication placed in SecurityContextHolder
↓
Authorization performed
↓
Controller executes
↓
SecurityContextHolder cleared
```

## Stateless Request LifeCycle

```
GET /profile
Authorization: Bearer TOKEN
↓
Token extracted
↓
Token authenticated
↓
Authentication created
↓
SecurityContext created
↓
Authentication placed in SecurityContextHolder
↓
Authorization performed
↓
Controller executes
↓
SecurityContextHolder cleared
↓
No authentication saved in HTTP session
```

Start the authentication process again using the credential carried by that request.



```
@Bean
SecurityFilterChain securityFilterChain(HttpSecurity http)
    throws Exception {

    http.authorizeHttpRequests(
        authorize -> authorize
            .anyRequest()
            .authenticated()
        )
        .formLogin(Customizer.withDefaults())
        .httpBasic(Customizer.withDefaults());

    return http.build();
}
```

